DataForce — build report (M1, M1b, M2a)

Status (17 October 2026):

Milestone	What it added	State
M1 ("jalon 1")	Data, CRM and statistics engine	complete and ratified
M1b	A local web interface, "Connect TamTam" over MCP, the 350-deal demo	complete, reviewed and fixed
M2a	Your feedback: drag-and-drop **analysis flows** with a pivot, statistics and model blocks; a **Companies** tab with the public French registry; an **AI model** in Settings with an **Ask** panel; a **light / dark** theme	complete, reviewed and fixed

Every part was built by Sonnet agents, independently reviewed for security, fixed and re-verified. **953 automated tests pass** (905 backend, 48 frontend).

Sources of truth.

File	What it holds
`docs/DECISIONS.md`	every decision and its reason
`docs/ARCHITECTURE.md`	the M1 contract
`docs/UI-CONTRACT.md`	the M1b contract
`docs/M2A-CONTRACT.md`	the M2a contract
`docs/BUILD-REPORT.md`	the source of this PDF, rendered by `docs/tools/build_pdf.py`

1. In one page

What DataForce is. An analysis workspace for sales and marketing teams. The team keeps a *minimal CRM* in DataForce: companies, accounts, people, deals and notes. Then it:

- looks up any company: "have we already dealt with them?";
- builds analyses by wiring blocks on a canvas;
- asks an AI about one account, with the AI's answers checked against the data.

TamTam already has better external data than we could build. So DataForce works at the CRM level, and calls TamTam only when a user explicitly asks for contact details.

The one rule that shapes everything. DataForce shows a number as a fact only when the evidence is strong enough. Otherwise it says **"not verified"** and gives the reasons:

- too few deals;
- an interval that is too wide;
- not significant once many comparisons are accounted for;

- for a model: not better than guessing, or tested on its own training data.

The AI never computes numbers. Any number it writes that is not in the data is flagged.

What is delivered.

Piece	What it does
Minimal CRM	Workspaces, companies grouping accounts, contacts with "reports to", deals, append-only notes and comments, one-click erasure
Companies (M2a)	One search box: have we interacted, and when last? A 360 page per company. On request, a lookup in the public French registry (address, SIREN, activity, size), with "Add to CRM"
Analysis flows (M2a)	Drag-and-drop canvas. Datasets come from the CRM, an uploaded CSV / Excel file or a read-only PostgreSQL database. Blocks: filter, sort, columns, group, join, **pivot**, stats test, chart, train/test split, linear and logistic regression, k-means
Statistics engine	Win rate, cycle length and deal size with 95 % confidence intervals and the "not verified" gates, reused by the stats and model blocks
AI model and Ask (M2a)	Gemini or Anthropic key entered in Settings, stored encrypted. The Ask panel on an account or company answers from its data, cites it, and flags numbers and quotes it cannot back
Connect TamTam (M1b)	Sign in on TamTam's page. The token is encrypted; paid lookups happen only after a confirmed click
Synthetic demo	350 deals with planted effects (seed 42) and a pure-noise twin (seed 1), now with companies and a year of dated notes
Command line and notebook	`dataforce …`; a proof notebook run against the answer key

Not delivered yet (by plan).

- M2b: title normalisation, the inferred org chart, meeting-transcript themes.
- M3: the MCP server and API for outside AI agents, login and hosting.

2. How it was built

The team works the same way for every milestone:

1. The tech lead (Claude Opus) writes the contracts first: the database model, the shared data types, the API shapes, and a written specification with non-overlapping file ownership.
2. Builder agents (Claude Sonnet, low effort, as requested) work in parallel.
3. Separate reviewer agents can read but not change the code, and must prove each finding.
4. Fixers close the findings with regression tests.
5. The tech lead re-runs everything, opens every screen in a headless browser, and commits in logical steps.

Round	Build	Ratify (read-only)	Fix
M1	foundation, generator, stats engine, LLM clean-up, integration	SR4, SR5, statistics ratification	3 fixers
M1b	API and CRM, TamTam connector, frontend, 350-deal demo	SR6 (API), SR7 (OAuth), SR8 (frontend)	2 fixers + tech lead
M2a	flow engine, flow API and data sources, companies and registry, AI assistant, flow-editor UI, companies/AI/theme UI	SR9 (flows and data), SR10 (companies and AI), SR11 (frontend)	3 fixers + tech lead

During M2a the agents hit a usage limit mid-build. They were resumed where they stopped once it reset, with no work lost.

Version control. Logical commits on `main`, with the tags `m1` and `m1b`. Pushing to a private GitHub repository is waiting for you to sign in to GitHub once (`gh auth login`).

3. Product decisions (and why)

Decision	Why
Not enough evidence → "not verified", always with the reasons; "not verified" is *not* "no effect".	A salesperson must be able to rely on whatever is shown as a fact.
The AI never calculates. Numbers come from code; the AI may only name, explain and cite them.	Numbers must be reproducible and auditable.
Notes and comments are append-only (a database trigger enforces it), except GDPR erasure.	Trust in what was said about a person, and the right to erasure.
Strict minimum on third parties. Emails and mobiles exist only after a confirmed TamTam lookup, encrypted, each with a *Delete*.	GDPR data minimisation.
Analysis is a flow of blocks (M2a, your request), not a fixed report.	Teams ask different questions; a pivot or a model should be two clicks away.
Blocks are configured, never programmed. There is no formula language, nothing is evaluated as code, and no model is saved.	A formula language and saved models are two classic ways in for attackers.
"Not verified" extends to models. A model is verified only if, on data it never saw, it beats the "learnt nothing" baseline with its confidence interval.	Most models on small CRM data are noise. The label says so.
External data is read-only. PostgreSQL runs one statement in a read-only transaction; files are copied into DataForce.	DataForce must never be able to change your systems.
A company groups accounts (M2a).	One customer often appears as several accounts: branches, subsidiaries.
The public registry is searched only when you click. The managers' list is never read; protected records are never stored.	Your search text leaves the computer only when you choose.
The AI key is entered in Settings, encrypted and never shown back.	Simple for you. The old "never paste the key" rule meant never paste it *into a chat*.
The Ask panel says what it sends (CRM names, titles, deals, notes; never emails or mobiles) and stores nothing.	You decide what goes to Google or Anthropic.
Local only, no login yet.	Login and hosting are M3.
350 demo deals; noise demo on seed 1.	Your choices. Seed 42 of the noise twin is one of the ~4 % that show a chance finding.

4. How the statistics work (plain language)

The three questions.

- *Win rate*: of the closed deals, what share was won?
- *Sales cycle*: days from creation to close, as a median.

- *Deal size*: the median amount.

Medians are used so one giant deal does not distort the picture.

Confidence intervals. Every number comes with the range that, 95 times out of 100, contains the true value.

- Rates use Wilson intervals.
- Differences between two rates use Newcombe intervals.
- Medians use a bootstrap with a fixed seed, so results are reproducible.

The "not verified" gates (approved by you, all configurable):

A result is "not verified" when…	Default
the group has too few deals	fewer than 30
a win rate rests on too few wins or losses	fewer than 10 of either
the range is too wide	more than ±15 points for a rate, ±30 % of the value for a median

Comparing groups.

- Each group is compared with the rest, using Fisher's exact test for rates and Mann-Whitney for days and amounts.
- The Benjamini-Hochberg correction keeps the expected share of false findings at 5 %.
- A finding is **verified** only if both sides pass the gates, the corrected test is significant, and the range of the difference excludes zero.

Real lines from the demo (350 deals, seed 42, the same in the stats block of a flow):

Group vs rest	Question	Result	Verdict
Inbound leads	win rate	72.5 % vs 24.2 %, +48.4 pts [+35.9, +58.6]	**verified**
Enterprise	sales cycle	median 106 vs 41 days	**verified**
Referral leads	win rate	72.0 % vs 39.1 %	not verified: only 25 deals (< 30), only 7 losses
Mid-market	deal size	€20,771 vs €15,879	not verified: q = 0.58, range [−190, +9,921] EUR includes 0

Models (M2a). A split block keeps a share of the rows aside (25 % by default). The model learns on the rest and is judged only on the rows it never saw.

Model	Verified only if, on the held-out rows	Example on the demo
Logistic ("will this deal be won?")	at least 30 rows; enough wins and losses; AUC interval above 0.5; accuracy interval above the "always predict the majority" rate	accuracy 81.5 % [69.2, 89.6] vs baseline 53.7 %; AUC 0.86 [0.74, 0.97]: **verified**
Linear ("how large will it be?")	at least 30 rows; R^2 interval above 0	R^2 0.65 [0.46, …] on amount by segment: **verified**

Clustering (k-means)	never: groups describe, they do not prove	3 groups of accounts, silhouette 0.43: **exploratory**

Two traps are caught automatically.

- Wiring the same rows into both "train" and "test" gives "not verified: test rows may overlap the training rows".
- A join that duplicates rows (one row per contact instead of per deal) gives "not verified: n is inflated".

Coefficients are labelled "associations, not causes".

5. The synthetic demo data

What the generator builds for a realistic small company:

- 30 companies grouping 122 accounts, with invented addresses in real French cities and no SIREN, so they never collide with real firms;
- 755 contacts with org charts;
- 350 deals;
- a year of dated notes and comments.

Everything is invented and deterministic: the same seed always gives the same data.

Kind	In the demo data
Planted (must be found)	Inbound wins far more often; enterprise deals are slower and larger than SMB deals
Trap (must stay "not verified")	Referral: a high win rate on at most 25 closed deals
Null (must find nothing)	Industry, region and owner. The **noise twin** (seed 1) has no effect at all

Reliability over 100 random datasets per variant (350 deals):

- every planted effect was found every time;
- about 8 % of planted datasets and 4 % of noise datasets show one chance finding.

That is the 5 % false-discovery control doing what it promises. Companies and note dates use separate random streams, so adding them changed no deal and no calibration number.

6. Architecture and structure

```
 browser: React UI (companies, flows, Ask, settings)        CLI · notebook
     │ JSON on 127.0.0.1 only, request guards
local API (FastAPI)
 ├─ flow engine (pandas, scikit-learn)
 │    └─ sources: CRM · CSV / Excel · PostgreSQL (read-only)
 ├─ companies ── public registry (api.gouv.fr, on click)
 ├─ Ask assistant ── Gemini / Anthropic (key sealed)
 ├─ TamTam connector (OAuth over MCP)
 └─ services layer (workspace-scoped, no SQL strings) ── PostgreSQL
```

Size.

Part	Lines
Backend code	about 16,200
Migrations	750
Tests	10,800
Frontend	4,600

Main folders.

Folder	Contents
`backend/app/services/`	CRM, companies, files, connections, flows, AI settings, enriched channels
`backend/app/stats/`	Intervals, tests, gates (shared with the flow blocks)
`backend/app/flows/`	Graph contract, engine, one module per block, data sources
`backend/app/registry/`, `backend/app/assistant/`	Public registry client; Ask context, checks and rate limit
`backend/app/connectors/`, `backend/app/llm/`	TamTam OAuth; Gemini / Anthropic / fake providers
`backend/app/api/`	Routes, request guards, error mapping, hosting of the interface
`frontend/src/`	Pages; `flows/` (canvas editor); `companies/`; `assistant/`; theme

Data model.

Table	Holds
`workspace`, `app_user`	one team (or one demo dataset); its members
`company` (M2a)	name, SIREN, address, activity, size, source; groups accounts
`account`, `contact`, `deal`	the CRM; contacts keep only name, title, reports-to and source
`note`, `comment`	append-only free text
`run`, `llm_call`	history of scans, generations and flow runs (summaries only); AI usage per workspace
`connector_credential`, `oauth_pending`, `contact_channel`	TamTam connection; sign-ins in progress; confirmed emails and mobiles (encrypted)
`uploaded_file`, `data_connection`, `flow` (M2a)	CSV/Excel files; PostgreSQL connections (password encrypted); saved flows
`llm_credential` (M2a)	the workspace's AI provider, model and encrypted key

Technology.

Choice	Why
Python 3.13, FastAPI, SQLAlchemy 2, PostgreSQL 16	Mature, typed, one database for everything
numpy, scipy, **pandas, scikit-learn, openpyxl** (M2a)	Reference implementations for statistics, tables, models and Excel files
React 19 + Vite + TypeScript, **@xyflow/react** for the canvas (M2a)	Small, fast, no UI kit; the canvas is loaded only when a flow is opened
Fernet encryption	Tokens, keys, passwords and enriched values are unreadable in the database and in backups
Hashed lock files (pip-tools, `package-lock.json`)	Reproducible, tamper-evident installs

7. Security

Principles.

- Local only.
- Another website cannot drive the app: Host allow-list, Origin plus a custom header, strict content-security policy.
- Secrets are encrypted at rest, and never shown, logged or sent to the browser.
- External systems are read-only.
- Text from notes, imports or servers is data, never instructions or HTML.

Reviews (read-only reviewers who must prove each finding).

Review	Scope	Findings	Status
SR4, SR5 (M1)	CRM database, LLM, statistics, demo	7 medium, 11 low, 7 info	all medium fixed
SR6–SR8 (M1b)	local API, TamTam sign-in, frontend	0 medium, 11 low, 11 info	all low fixed
SR9 (M2a)	flows, uploads, PostgreSQL	**1 high**, 7 medium, 6 low, 1 info	high and every medium fixed with tests; 3 low/info accepted with a reason
SR10 (M2a)	companies, registry, AI assistant	1 medium, 5 low, 2 info	all 8 fixed with tests
SR11 (M2a)	frontend, npm supply chain	1 low, 1 info	low fixed

The M2a high finding. A crafted PostgreSQL query could end the read-only transaction and write to the connected database. The cause was a hand-written statement splitter, fooled by `$$` quoting. The query now runs as a *prepared statement*, which the database server itself refuses to split into two commands, whatever the quoting. Regression tests try every quoting trick; a watchdog also cancels any query that runs past its time limit.

M2a medium findings fixed.

- A connection whose server was changed kept the old password and would have sent it to the new server. The password must now be re-entered.
- **Heavy inputs could hog the app.** A huge median comparison or a 80,000-column CSV header could run for minutes. Runs now have a concurrency limit, cooperative time limits inside long blocks, and size checks before

parsing.

- A pivot could produce a 20 MB answer. Its view is now capped.
- A model tested on its own training data, or statistics on rows duplicated by a join, could show "verified". Both are now caught.
- The assistant's number check could be fooled ("EUR9999", "twelve", numbers taken from notes). Numbers now count only when they appear in code-computed facts; numbers found only in notes are listed apart.

Main things the reviews confirmed hold.

- No route returns or changes another workspace's data.
- Cross-site requests, DNS rebinding and form posts are refused.
- Uploads are accepted only on their own route, with every guard.
- The registry receives your search only on a click (now a guarded POST). It never reads the managers' list, and protected records cannot be stored.
- The AI key never appears in a response, a log or a URL. A website cannot trigger AI calls, and calls are capped at 60 questions per hour per workspace.
- Notes and names cannot break out of the "untrusted text" wrapper sent to the AI.
- The npm dependencies (113 packages) are pinned and integrity-checked, with install scripts disabled.

Accepted residuals (written down):

- **No login until M3.** Any program on this computer can use the app.
- **PostgreSQL.** The database role you connect with remains the real boundary: use a read-only role. `sslmode=require` encrypts but does not verify the server certificate; use `verify-full` for remote databases.
- **Timed-out runs.** A run that times out keeps its worker until the current computation step ends. It holds its slot meanwhile, so runs cannot pile up.
- **Encryption key.** One key, kept in `backend/.env`, with no rotation yet. Losing it means re-entering the AI key and reconnecting TamTam.
- **Unverified assumptions.** TamTam's tool list and prices, and live AI answers, are unverified until you connect real accounts.

8. Verification results

Check	Result
Backend tests	**905 pass**: CRM, statistics, demo, LLM, TamTam, API, flows (every block, against hand-computed values), sources (PostgreSQL attacks against a real local database), companies, registry, assistant
Frontend tests	**48 pass**: org-chart tree, formatting, sign-in address check, flow graph rules, pivot rendering, answer citations, theme; type check and build clean
Lint, migrations	ruff clean; models and migrations identical; dev database at `0005_m2a`
End to end, through the running app	one flow using all 12 block types on the demo. Inbound and outbound verified, referral not verified (as in M1); the logistic model verified (AUC 0.85); clusters returned; the leakage and join traps caught
Screens	every page opened in a headless browser, in light and dark mode, with no console error; a real registry search for "Dataiku" returned the public record
Notebook	re-run: planted seed 42 finds 5 of 5; noise seed 1 verifies nothing out of 93 comparisons

Caught during the verification itself.

- **Every demo company showed "last interaction: today".** The demo notes had no dates. They now carry a year of synthetic history, which needed a checked "original date" option for imported notes.
- **Dates showed a stray "02:00".** Dates are now shown without a time.
- **The canvas stayed light in dark mode.** It now follows the theme switch.
- **The editor's field names drifted from the API on one point** (a connection's last error). The two now match.

9. How to run it

```
make db-up                                    # local Postgres
make migrate                                  # schema (after the one-time Python setup, see README)
backend/.venv/bin/dataforce demo generate --variant planted --seed 42 --replace
backend/.venv/bin/dataforce demo generate --variant noise   --seed 1  --replace
make ui                                       # then open http://127.0.0.1:8800
```

Try:

Where	What to do
Companies	type "alder", or search the registry for any French company
Analysis	*New flow* → a template, then *Run all* and click a block to see its result
Settings → AI model	paste a Gemini or Anthropic key, *Test*, then *Ask* on a company

Theme	the button in the header

10. What comes next

Milestone	Content
M2b	Title normalisation (FR/EN dictionary, AI only for unknown titles); org-chart rules with their evidence; transcript import and meeting themes counted by code, named by the AI with verified quotes
M3	MCP server and API so outside AI agents get exact results; login; hosting; flow results saved and shared

Open questions for you.

1. **CRM scope.** After trying Companies, accounts and flows: what is missing?
2. **TamTam.** After connecting, does *Check connection* list the tools we expect, and what are your real credit prices?
3. **AI.** After adding your key, are the Ask answers useful? Should the assistant also be able to *run* a flow for you, for example "pivot my deals by segment"?
4. **Blocks.** Which block do you miss most: export to CSV, time series, a decision tree, or a cohort view?
5. **GitHub.** Type `! gh auth login` once, and the build is pushed to a private repository.

Glossary

Term	Meaning
Confidence interval (CI)	The range that most likely contains the true value; narrower with more data
Gate	A minimum-evidence rule; failing one makes a result "not verified"
FDR	The expected share of reported findings that are false, held at 5 %
Train / test split	Keeping some rows aside to judge a model on data it never saw
Baseline	What a model that learnt nothing would score; a model must beat it
AUC	How well a model ranks wins above losses: 0.5 is a coin toss, 1.0 perfect
R^2	Share of the variation a regression explains: 0 is nothing
Pivot	A table with one dimension in rows, another in columns, and a sum or count in each cell
SIREN	The 9-digit French company identifier
Prepared statement	A query the database checks as one single command before running it
MCP	Model Context Protocol: the standard way AI agents call tools